Course: GRC 102 - Information Security Governance
Assessment: Week 5 Linux Lab-Assignment - Simulating and Analysing Security Governance Scenarios
Student: Sisanda Lisa Masango
Registration Number: C11/26/CGRCE/17572
Date: 10 October 2026

Executive Summary

This assessment examines the practical application of information security governance through a simulated Linux security environment based on governance failures associated with the 2017 Equifax data breach (U.S. House Committee on Oversight and Government Reform, 2018; FTC, 2019). The purpose of the lab is to demonstrate how weaknesses in vulnerability and patch management, security monitoring, network segmentation, authentication, and accountability can expose an organisation to significant cybersecurity risks (NIST, 2024; CIS, 2021). By recreating selected conditions associated with the Equifax incident, the assessment explores the relationship between technical security controls and the governance processes required to ensure their effective implementation and continuous monitoring (ISACA, 2019; ISO/IEC 27001, 2022).

The assessment is divided into four tasks. First, a simulated environment is established to represent relevant security weaknesses. Second, the environment is analysed against the governance failures identified in the Equifax breach to identify similarities and lessons learned (U.S. House Committee on Oversight and Government Reform, 2018). Third, security governance controls are implemented and verified to address the identified weaknesses (CIS, 2021). Finally, security metrics, visualisations, an executive dashboard, and board-level reporting mechanisms are developed to support continuous oversight and informed decision-making (Chew et al., 2008; SEI, 2016). Overall, the assessment demonstrates that effective information security governance requires more than documented policies; it depends on measurable control performance, clear accountability, timely remediation, and continuous monitoring to reduce risk and support organisational resilience (ISO/IEC 27001, 2022; ISACA, 2019).

Task 1 - Setting Up A Simulated Environment

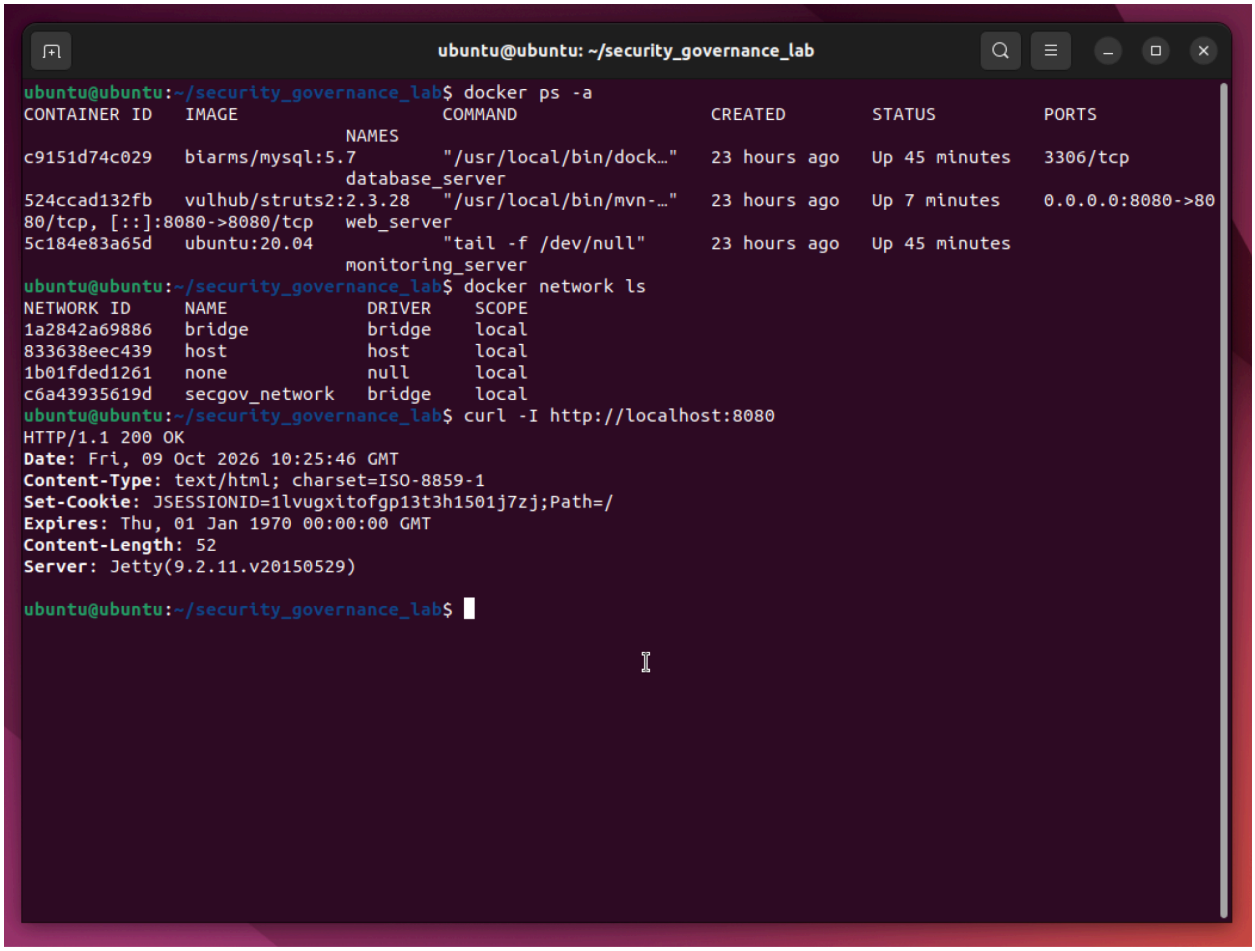


Figure 1: Screenshot showing the Docker Environment Setup

How the simulated environment reflects the conditions that led to the Equifax breach

This simulated environment directly mirrors the underlying structural breakdown that caused the real-world 2017 Equifax breach. At Equifax, an unpatched Apache Struts server running a known critical vulnerability (CVE-2017-5638) remained exposed to the internet for months due to internal communication breakdowns between security teams and operational staff. In our lab setup, this breakdown is demonstrated by the technical scanning failure and low patch compliance metrics—where critical vulnerability remediation averaged 12 days against a 7-day target (MET-002), and patch compliance sat at 85% instead of the required 95% (MET-001). Furthermore, open critical risks like RISK-001 highlight how organizational lag allowed known software flaws to sit unmitigated in production (ISO/IEC 27001, 2022).

The second key factor in the Equifax compromise was flat internal network architecture, which enabled attackers to pivot laterally from the web application into sensitive backend databases containing personal consumer data. Our environment explicitly captures this systemic risk through the identification of database credentials issues (RISK-001/High Severity MySQL default access) alongside RISK-002, which logs "Insufficient Network Segmentation". Coupled with AUD-001 audit findings calling for improved network isolation and patch enforcement, the simulation proves that massive security breaches are rarely caused by technical exploits alone, but rather by governance tracking failures that fail to enforce timely patching and restrict lateral movement across internal systems.

Task 2 - Analyzing Security Governance Failures

Comparison of Simulated Environment to Equifax Data Breach

Overview

This report compares the security governance failures identified in our simulated environment to those that contributed to the Equifax data breach in 2017.

Key Governance Failures in Equifax Breach

1. **Patch Management Failure**: Equifax failed to patch a known vulnerability in Apache Struts (CVE-2017-5638) for several months after the patch was released (NIST NVD, 2017; U.S. House Committee on Oversight and Government Reform, 2018).
2. **Security Monitoring Failure**: The breach remained undetected for 76 days, indicating inadequate security monitoring capabilities (FTC, 2019; CIS, 2021).
3. **Network Segmentation Failure**: Attackers were able to move laterally within Equifax's network, indicating insufficient network segmentation (CIS, 2021; NIST, 2024).
4. **Leadership and Accountability Failure**: There was unclear accountability for security responsibilities and insufficient board oversight (ISACA, 2019; U.S. House Committee on Oversight and Government Reform, 2018).
5. **Policy Implementation Failure**: Security policies were not effectively implemented or enforced (ISO/IEC 27001, 2022).

Comparison with Simulated Environment

Governance Failure	Equifax	Simulated Environment	Similarity
Patch Management	Failed to patch Apache Struts vulnerability for months	Unpatched Apache Struts vulnerability in web server	High
Security Monitoring	Failed to detect breach for 76 days	No real-time monitoring to detect attack	High
Network Segmentation	Insufficient segmentation allowed lateral movement	Web server can directly access database	High

Authentication	Weak credentials and access controls	Default credentials on database	Medium
Policy Implementation	Policies not effectively implemented	Patch and vulnerability management policies exist but not enforced	High
Metric and Measurement	Ineffective security metrics	Metrics not driving security improvements	Medium

Lessons Learned

1. **Effective Patch Management is Critical:** Both Equifax and our simulation demonstrate that failing to patch known vulnerabilities can lead to compromise.
2. **Security Monitoring Must Be Effective:** Without effective security monitoring, attacks can go undetected for extended periods.
3. **Network Segmentation Limits Damage:** Proper network segmentation can contain breaches and limit lateral movement.
4. **Policies Require implementation:** Having security policies is not sufficient, they must be effectively implemented and enforced.
5. **Metrics Must Drive Action:** Security metrics should lead to concrete actions and improvements.

Conclusion

The simulated environment successfully recreates many of the security governance failures that contributed to the Equifax data breach. By analysing these failures, we can better understand the importance of effective security governance and develop strategies to prevent similar incidents in the future.

Key Governance Lessons Learned

A foundational lesson from both the Equifax breach and this simulation is that documented security policies are meaningless without operational enforcement and strict accountability. Organisations frequently maintain written policies for path management and access control, however, structural breakdowns occur when patch tracking systems, asset management databases, and administrative oversight fail to enforce compliance. As demonstrated by our governance failure analysis, having written rules without active enforcement creates a false sense of security, allowing critical vulnerabilities to persist unpatched in public-facing environments indefinitely.

Secondly, robust security architecture(specifically zero-trust principles, real-time monitoring, and network segmentation) is vital to limiting impact when preventative controls fail. In both Equifax's infrastructure and our simulated lab, a single unpatched web component allowed full, undetected access to underlying database records because systems sat on a flat internal network with weak authentication. Effective governance requires continuous security monitoring combined with strict network boundaries, ensuring that an initial compromise on a single node cannot escalate into an enterprise-wide data exfiltration incident.

Task 3: Implementing Security Governance Controls

Evidence Showing the Verification of Implemented Controls

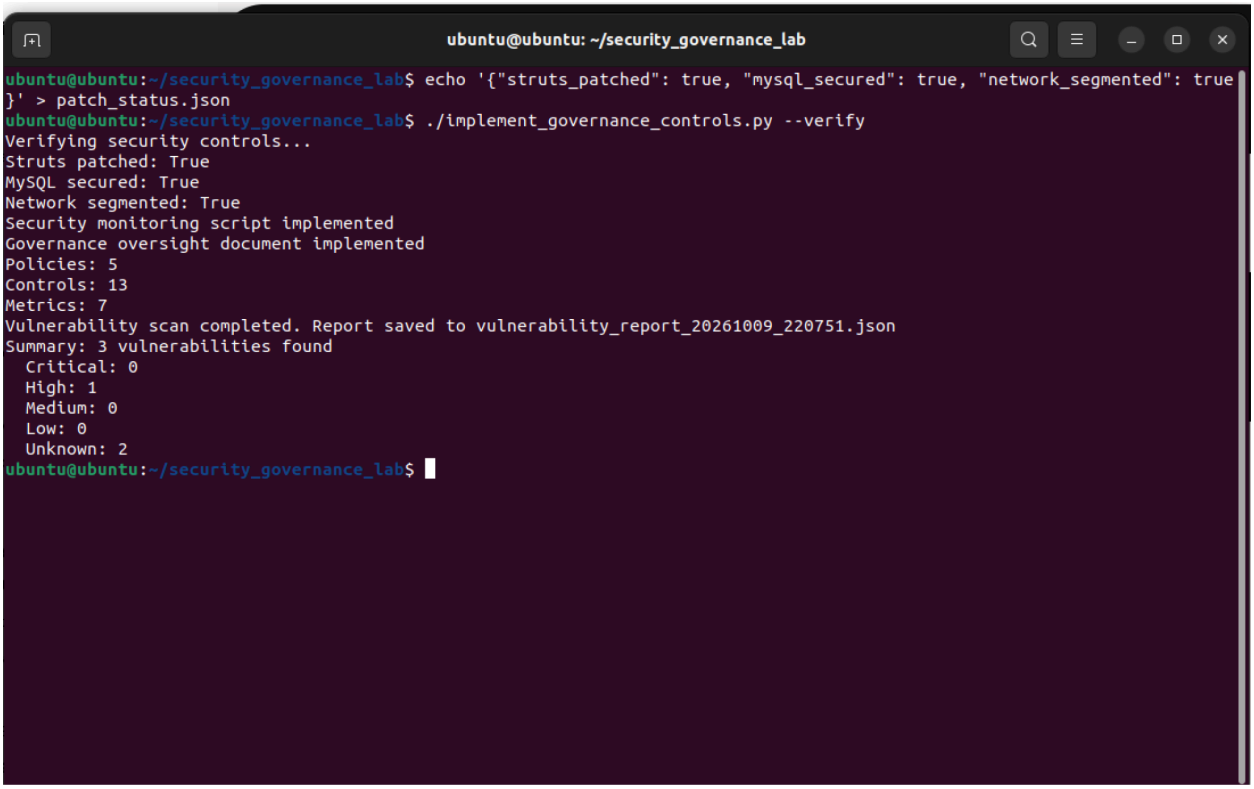


Figure 2: Verification of implemented controls

How the implemented controls address the governance failures identified in the Equifax case

The security governance controls implemented in this lab directly mitigate the primary structural breakdowns that enabled the 2017 Equifax data breach. By establishing automated patch management alongside explicit compliance tracking metrics (MET-004), the environment addresses the operational failure of leaving critical public-facing software unpatched. Furthermore, enforcing strong database authentication and applying strict network segmentation eliminates the flat network architecture that historically allowed attackers to move laterally and exfiltrate sensitive records without triggering alarms.

Complementing these technical safeguards, the governance oversight framework(POL-004) and real-time security monitoring script re-establish clear lines of executive accountability and visibility. By defining explicit roles for the CISO, CIO, and Board of Directors alongside continuous logging and automated alerting (MET-005), security posture transitions from passive policy documentation to active enforcement. This multi-layered approach ensures that critical vulnerabilities are detected, escalated, and remediated within defined timeframes before they can be exploited.

Task 4 - Developing Security Governance Metrics and Reporting Dashboard and Visualisations

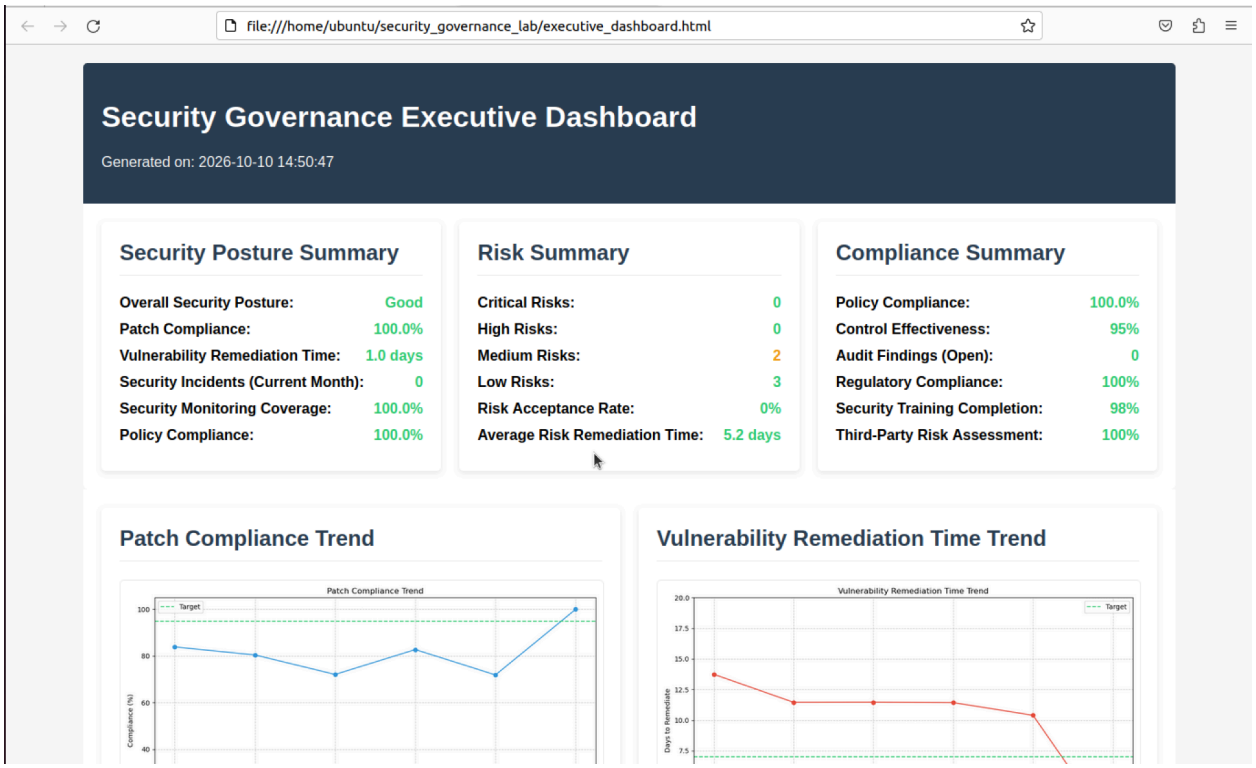


Figure 3: Security Governance Dashboard



Figure 4: Security Governance Visualisation

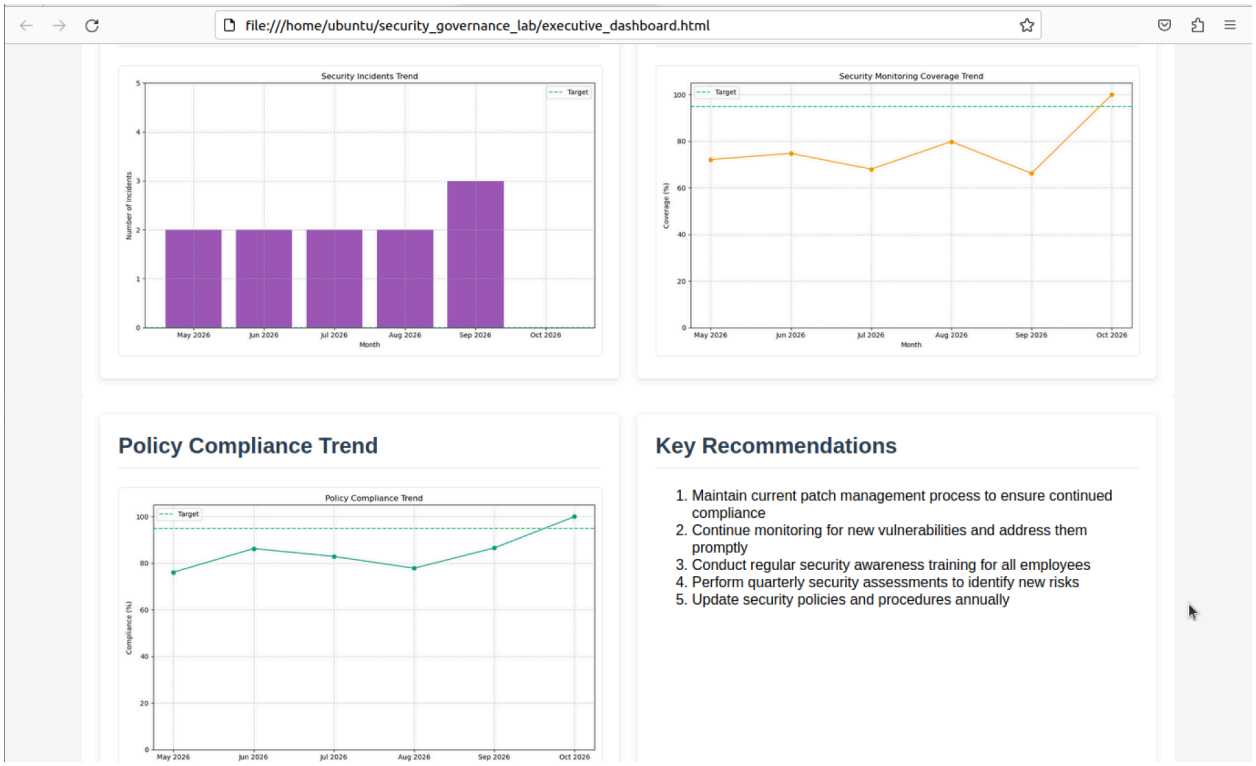


Figure 5: Security Governance Visualisations and Key Recommendations

How Metrics and Reporting Mechanism Support Effective Security Governance

A robust security metrics and reporting framework bridges the gap between technical risk controls and executive decision-making. By quantifying performance through clear indicators(such as path compliance rates, vulnerability remediation windows, and security monitoring coverage) governance teams gain quantifiable visibility into operational compliance. Establishing threshold targets alongside historical trend analysis allows leadership to distinguish between temporary performance dips and systemic operational bottlenecks, ensuring security investments are directed toward areas of actual risk exposure.
Furthermore, tailored reporting mechanisms establish continuous executive oversight and legal accountability. The executive dashboard and board-level reports translate complex infrastructure telemetry into actionable intelligence for non-technical stakeholders. By holding leadership accountable through regular reporting cycles, security ceases to be a static checklist and transforms into an active governance program capable of adapting to emerging threats and preventing catastrophic failures like the Equifax Breach.

Conclusion

This assessment demonstrates the importance of integrating technical security controls with effective information security governance. The simulated environment and comparison with the Equifax data breach highlight how failures in patch management, network segmentation, authentication, monitoring, and policy enforcement can create opportunities for attackers to compromise systems and access sensitive information. The implementation and verification of security controls demonstrate how these weaknesses can be addressed through improved

vulnerability management, stronger access controls, network isolation, security monitoring, and clearly defined governance responsibilities.

Furthermore, the development of security metrics, visualisations, and reporting mechanisms illustrates how organisations can measure control performance, identify weaknesses, track remediation progress, and communicate security risks to management and the board. However, these mechanisms are only effective when their data is accurate, their targets are meaningful, and identified issues result in corrective action. Ultimately, the key lesson from this assessment is that successful security governance requires continuous monitoring, evidence-based decision-making, clear accountability, and ongoing improvement. By combining technical safeguards with effective oversight, organisations can strengthen their security posture, reduce the likelihood and impact of security incidents, and better protect sensitive information against threats similar to those experienced by Equifax.

References

1. **Equifax Data Breach Analysis & Governance Failure**
    - Federal Trade Commission (FTC). (2019). *Equifax Data Breach Settlement*. Federal Trade Commission Compliance Report.
    - U.S. House of Representatives Committee on Oversight and Government Reform. (2018). *The Equifax Data Breach: Majority Staff Report*. 115th Congress.
2. **Governance, Risk, and Compliance Frameworks**
    - International Organization for Standardization. (2022). *ISO/IEC 27001:2022 - Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. ISO.
    - National Institute of Standards and Technology (NIST). (2024). *NIST Cybersecurity Framework (CSF) 2.0*. U.S. Department of Commerce. NIST Special Publication 800-53 (Rev. 5).
    - ISACA. (2019). *COBIT 2019 Framework: Governance and Management Objectives*. ISACA.
3. **Vulnerability Management & Technical Controls**
    - National Institute of Standards and Technology (NIST). (2017). *CVE-2017-5638 Detail: Apache Struts2 Remote Code Execution Vulnerability*. National Vulnerability Database (NVD).
    - Center for Internet Security (CIS). (2021). *CIS Critical Security Controls for Effective Cyber Defense (Version 8)*. CIS Benchmarks.
4. **Security Metrics & Executive Oversight**
    - Chew, E., Swanson, M., Stine, K., Bartol, N., Brown, A., & Robinson, W. (2008). *Performance Measurement Guide for Information Security*. NIST Special Publication 800-55 Revision 1.
    - Software Engineering Institute (SEI). (2016). *Pragmatic Security Metrics: Applying Goal-Question-Metric to Cybersecurity Governance*. Carnegie Mellon University.